

300653868

CYBR 373 - GRC Risk Assessment Assignment

Student Name: Kamal Hafiz

Course Code: CYBR 373

Due Date: 11 August 2025

Submission Date: 12 August 2025

AI Disclosure: [Used ChatGPT for planning]

Section A: Risk Framework & Priority Assets (8 marks)

Part 1: Risk Rating Definitions (3 marks)

CIA Triad Definitions for EtherSpace Data Center Context

Confidentiality: Confidentiality is to protect sensitive data and systems from unauthorized access. In the context of EtherSpace, it is important for the company to ensure that transactional data and customer data, such as their full name, address, phone number and email is secure and confidential. Furthermore, EtherSpace also needs to keep their business information confidential as competitors could gain advantage if this data gets leaked. All of these different types of data can be kept confidential by having strict access controls in place, as well as using encryption to store data. This will secure the data from any unauthorised person trying to access it, or any leaks.

Integrity: Integrity in the cybersecurity context refers to the accuracy, reliability and protection against unauthorised modification of data and systems. In the context of EtherSpace, they must insure integrity by making sure that only authorised people has access to server rooms where the data is stored, backing up data regularly, and having strong authentication practices. EtherSpace has RFID keys to monitor who accesses the server rooms, and customers must verify their address to reset their passwords, which will verify the person requesting a password change is authorised to do so. The systems are kept reliable by having automatic updates for employees computers.

Availability: Availability is where data and systems are accessible and available when required. In the context of EtherSpace, ensuring availability means making sure that employees have access to their own offices and spaces like the supply room. It also includes ensuring that EtherSpaces servers are available to users. The web hosting is outsourced to another company and they guarantees 99.99 percent uptime, which is important for availability, as if the website is down, customers will not be able to access their server which could lead to disruptions for the user and bad reputation for EtherSpace, hence it is vital to ensure services are available.

Likelihood Scale (5 levels)

Level	Category	Description
5	Almost Certain	It is very easy for a threat to exploit a vulnerability, and can be done without specialist skills and can be done by anyone, thus making the threat almost certain. An example of this could be a phishing email which targets the users of EtherSpace. An attacker could send out a phishing email to the users and if any of them click on the link, the attacker can gain all of their information. This attack requires no technical knowledge or advanced computational power, just a simple email which if clicked on, can be deadly. The only control for this is user awareness, however, if the phishing email seems very realistic, it could work.
4	Highly Probable	A threat that is very likely to happen, requires some technical knowledge, there are controls in place, but they don't always work. One example from EtherSpace is an employee forgets to properly shut the door, the access system will only beep after an hour. This is highly probable as an attacker could sneak in and do damaging to property and stealing data within the one hour where the alarm doesn't go off.
3	Possible	A threat can happen, there are controls in place, but they can be exploited with the correct technical skills and computational power. One example for EtherSpace would be the reuse of weak or default passwords given to users. Since users are given default passwords for their servers, if they reuse this,

		they could potentially be exposed to threats as the default passwords aren't very secure and could potentially be guessed by the attacker.
2	Possible but Unlikely	A threat is unlikely to exploit a vulnerability, the controls in place are strong, but they can still be exploited if there are unusual conditions. An example of this level of threat could be an unauthorized person gaining access to the CEO's office. This is possible but very unlikely as there are controls in place to prevent this. The door to the office is locked, but if an attacker can open the lock, which is possible but unlikely, then attackers will have access to important documents and business information.
1	Almost Never	A threat is almost impossible to exploit a vulnerability, there are very strong controls in place to stop such attacks. An example of this would be an attacker altering the .csv file which stores customers data. This is stored in a network attached storage device in the office supply room, which is almost impossible to alter without employee level access.

Impact Scale & Valuation Criteria

Level	Category	Business Consequences	Asset Valuation Criteria
5	Catastrophic	Loss of life, significant financial and reputational loss, business is disrupted and cannot operate until recovery which may take years. An example of this could be if an attacker gained access to the DMZ and therefore could access all the customers servers. This would cause catastrophic damage, as the attacker would steal information of all the customers, and even potentially carry out a DDOS attack so users cannot access their servers.	High Impact Assets
4	Severe	May take weeks or months to recover from the attack, would cause major financial and revenue loss, negative media reports and reputational damage. An example of this could be the attacker gained access to the weekly backup of customer data. This is severe as it would expose all the data of customers who signed up during the week, but not everyone.	High Impact Assets
3	Moderate	The attack may cause the company to be down for weeks, or days, and will cause temporary loss of services for customers. This will cause customers to be annoyed and potentially switch to a different company, which may cause a loss of revenue. An example of this would be if root passwords are emailed to the wrong customer, maybe another customer accidentally accesses another customers server, but this does not cause distractive damage.	Medium Impact Assets
2	Minor	The attack didn't affect too much of the business operations, the services of the company may be down for a few hours but would come back up promptly as it is an easy fix. An example of this would be if an engineer's computer crashes, they could just reboot their computer, this is going to cause minimal damage since it only affects one engineer, and not all of the users.	Low Impact Assets
1	Negligible	The attack did not cause any noticeable damage to customers, and operations continue like normal shortly after the attack, the engineers are able to fix the issue and patch the system within minutes so there is not loss of	Low Impact Assets

		functionality or data. An example could be a 5 minute Wi-Fi outage, which disrupts employees connection to the internet, .	
--	--	--	--

Part 2: Priority Asset Analysis (5 marks)

Template 1: Asset Analysis

Asset ID	Category	Asset Name	Description	CIA Classification	Valuation (H/M/L)	Business Justification
P01	Personnel	CEO	The CEO owns and overlooks business operations.	Confidentiality	High	The CEO is one of the most critical aspects of the business, without the CEO, the business wouldn't be able to operate. The replacement cost would be high as it would be hard to find another person with enough experience to fill this role.
P02	Personnel	Engineer	Engineers provide customer support, ensure all components work properly in the data centre like the electrical systems, wiring, cooling, hardware and software.	Availability	High	Engineers are in charge of ensuring the smooth operation of the business without them, there would be issues and customers would complain, hence they are of high value. Engineers require the correct skillsets to work at EtherSpace so it would be hard to find a replacement engineer with the correct knowledge.
P03	Personnel	Contractors	Contractors are in charge of all office related maintenance, like plumbing, building repairs and cleaning.	Availability	Medium	These contractors are an important part of the business, but they aren't as important as the CEO or the engineers, there are many different contractors that could be used, so they can be easily replaced and for a similar price. Their impact is more on the physical aspect of the business, ensuring the office remains a safe and healthy environment for the workers, not so much for the business operations.
H01	Hardware	Servers (24)	The company owns 24 servers which cost \$15,000 per unit. Each server can support up to 20 virtual servers and are all located on one DMZ.	Availability	High	This is the companies most expensive hardware asset, so it would be very expensive to replace. It is vital that all the servers are up and running for optimal performance. Without these servers, business operations would not continue

						as customers wouldn't be able to access their servers, thus the availability of the servers is vital.
H02	Hardware	Power systems	The power systems, ensure that all the servers and employee devices are getting power.	Availability	High	This is a high value asset, because without power, the servers won't run and so customers wouldn't be able to access their servers. This would disrupt business operations. The power module, could be replaced, however would cost \$6000 per unit, which makes it a high value asset.
H03	Hardware	Routers	A router connects devices to the internet by directing data packets.	Availability	High	This is a high value asset because connection to the internet is crucial in this business, and without internet connections, the servers would not be able to run. The cost to replace a router is \$5000 per unit, which is not too expensive, however the impact this will have on the business is high, due to the lack of availability of services.
H04	Hardware	Smoke detectors	A smoke detector is used to detect smoke, in case of a fire, it will sound an alarm.	Integrity	Medium	This asset is not as crucial for business operations as other assets, however it is important to have at smoke alarms to detect smoke and fire, hence it is ranked as medium. It is very cheap to replace a smoke detector, costing only \$15 per unit.
D01	Data/Software	Customer Data	Customer data is information that the customer keeps on their virtual machine.	Confidentiality	High	Customer data is a very important asset in this business. Customers are effectively paying the business to store this information into their virtual machines, and they trust the business to keep it secure, and any loss or breach of this data would have serious consequence including both financial, and reputational loss for the business.
D02	Data/Software	Transactional data	This is information about the types of services that the customer has purchased, including things like customer	Confidentiality	High	Any data which includes customer information must be kept secure and is a high value asset to the company. This is data which cannot be replaced, and has a high impact on the regulatory requirements.

			information, service information and sale information.			
D03	Data/Software	Firewall	Firewalls are put in place for security reasons, to monitor and control incoming and outgoing network traffic based on security rules.	Integrity	High	Firewalls are a high value asset, because they protect the servers from any potential malware and malicious network traffic. The firewall is free, so there are no replacement costs. If there is no firewall setup, then the business may be exposed to cyber-attacks, which if they succeed can cause significant loss to the business depending on the severity of the attack.

Section B: Priority Risk Assessment (12 marks)

Template 2: Risk Assessment Matrix

Risk ID	Asset ID	Threat	Vulnerability	Risk Description	Consequence	Impact	Likelihood	Risk Rating
R01	P02	Attacker accessing office supply room.	Access control system only sounds alarm after an hour of the office supply room door being left open.	If an engineer accidentally doesn't close the door properly, the attacker has a 1 hour window to go inside the office supply room undetected to tamper with or steal assets. They could be installing spyware into the room, to gather information from the engineers or the CEO.	The consequence of this happening would be the attacker stealing office supplies, or the attacker could install spyware in the room to listen in to conversations to try get confidential information.	3	2	6
R02	P02	Engineer leaks company information	The lack of background check for employees	The potential damage which can be caused by	The consequences of this threat would be that	4	5	20

			applying to the job is where the vulnerability is.	this threat is very serious. The attacker could expose confidential company data to competitors, install spyware around the office. The attacker could also steal customer data.	the companies data is leaked and competitors gain an advantage, which lead to a decrease in clients and revenue, which would overall have a significant negative impact on the business operations.			
R03	H01	Lateral Movement within servers by an attacker.	All of the 24 servers are on a single DMZ	If one virtual machine is compromised by an attacker, the attacker can move to other servers within the DMZ.	All of the companies servers become compromised, because of one compromised server, all users are at risk of their data being stolen as well.	5	3	15
R04	D01	Customer data stolen by attacker	Default password not changed by user	If the attacker can guess the default password, then the attacker can gain access to the server.	Once logged into the server, the attacker can steal valuable customer data.	4	2	8
R05	D03	Attacker bypasses firewall and gains access to server.	firewall rule is not configured properly or it is not regularly audited.	If the attacker finds a way to bypass a rule in the firewall, the attacker can gain access to the server.	The attacker gains access to the server and can steal user data or even do a DDOS attack to disable services from running.	5	1	5
R06	H02	Earthquake	The location of the office, which is in Wellington lies on a fault line.	Being on a fault line increases the risk of earthquakes.	Building collapses and business loses all of its physical assets	5	3	15

Detailed Risk Analysis

Risk R01: Unauthorised person accessing the office supply room.

Threat: Attacker enters the office supply room.

Vulnerability: Access control system alarm goes off after an hour of door being left open.

Risk Description: Attacker could wait 5 minutes after the employee accidentally leaves the door open and go inside without the alarm going off.

Business Impact: Stealing office supplies wouldn't have a big impact on the business, however the impact has the potential to be catastrophic if the attacker installs spyware devices which listen into conversations and from this the attacker can derive confidential information which can harm business operations and benefit competitors.

Risk Calculation: Impact [3] × Likelihood [2] = Risk Rating [6]

Risk R02: Engineer leaking company and user data.

Threat: Engineer secretly leaks data.

Vulnerability: No background check is done when hiring employees.

Risk Description: An attacker could apply to work at EtherSpace as an Engineer and then once the attacker gets the job, they can leak all the data and inside information about the business.

Business Impact: This will have a serious impact on the business because if users find out that their data is being stolen, then they will not use EtherSpace again and will switch to another company.

Risk Calculation: Impact [4] × Likelihood [5] = Risk Rating [20]

Risk R03: Attacker accessing all servers.

Threat: Attacker moving laterally between servers to steal customer data and other information.

Vulnerability: All of the servers are in a single DMZ.

Risk Description: If the attacker can successfully gain access to one compromised server, then they could potentially move to other servers through the compromised one, allowing them to access all 24 of the servers.

Business Impact: The impact of this would be all of the customers of EtherSpace would be compromised and all of their data on their servers would have been stolen.

Risk Calculation: Impact [5] × Likelihood [3] = Risk Rating [15]

Risk R04: Attacker guessing default password

Threat: Attacker has access to the users password.

Vulnerability: No mandatory control for user to change their provided default password to their server.

Risk Description: Attacker successfully cracks the default password as it is not as secure as a custom one, and then has access to the users server.

Business Impact: If an attacker gains access to a customer's server, they could steal sensitive customer data.

Risk Calculation: Impact [4] × Likelihood [2] = Risk Rating [8]

Risk R05: Attacker bypasses firewall

Threat: If a firewall is not configured properly, it can be bypasses by an attacker.

Vulnerability: misconfigured firewall that is not updates regularly.

Risk Description: An attacker finds a vulnerability in the firewall and knows how to exploit the firewall which allows the attacker to gain access to sensitive customer data and other information.

Business Impact: Reputational loss, financial loss.

Risk Calculation: Impact [5] $\times$ Likelihood [1] = Risk Rating [5]

Risk R06: Earthquake

Threat: The EtherSpace office is located in Wellington, which lies on a fault line.

Vulnerability: Being on a Faultline means that the office is at a higher risk of an earthquake.

Risk Description: If there was an earthquake, then depending on the severity of the earthquake, the damage could be severe, with damage to the physical assets in the office like the servers and computers.

Business Impact: With damage to physical assets, the business would have to relocate or just rebuild which will cost a lot of money to replace all the assets.

Risk Calculation: Impact [5] $\times$ Likelihood [3] = Risk Rating [15]

Section C: Risk Control Strategy (8 marks)

Template 3: Control Analysis

Risk ID	Existing Controls	Recommended Controls	Residual Impact	Residual Likelihood	Residual Risk
R01	Access Control System with a 1 hour delay in the alarm system	Reduce the alarm sound time from 1 hour to 2 minutes.	3	1	3
R02	No existing controls	A thorough background check, including police check to ensure there is no previous criminal history.	3	1	3
R03	Single DMZ	Creating multiple DMZ's by classifying the servers into different categories.	3	1	3
R04	Default account credentials are required to log in, and can be changed optionally.	Make the default password only valid for a one time use, then make it mandatory for user to put their own password, with a minimum length and extra requirements.	5	1	5
R05	Firewall setup initially with rules.	Conduct regular audits on the firewall rules every few months, to ensure it is up date to protect against the newest types of attacks.	4	1	4
R06	None	Regular building audits to check that the building is secure and stable, also change backups from weekly to daily.	4	3	12

Detailed Control Analysis

Risk R01 Control Strategy

Current Situation: Currently, the alarm system only triggers after an hour if an employee doesn't close the door properly. This leaves enough time for an attacker to sneak into the office supply room and steal office supplies or install spyware.

Recommended Controls: The recommended controls would be to reduce the time it takes for the alarm to ring, from 1 hour down to 2 minutes. This way an attacker wouldn't have the time to go into the office supply room.

Implementation Considerations: The cost shouldn't be too high, it's just a case of reconfiguring the alarm system. The resources required would be a contractor to come and carry out the work. It would only take maybe around a week to carry this out.

Residual Risk Justification: The impact is 3 because the damage could still be moderate if carried out correctly and swiftly, the likelihood is down to 1 because the alarm is more time sensitive.

Risk R02 Control Strategy

Current Situation: Currently, EtherSpace doesn't conduct any background checks when hiring people.

Recommended Controls: Controls I would recommend to resolve this would be to conduct a background check, including a police check, to ensure that the employee doesn't have a criminal history and doesn't affiliate in anyway with any competitor companies who may benefit from insider information.

Implementation Considerations: In order to achieve this, the CEO may want to consider hiring an employee who overlooks HR. This will become useful, especially when the company grows, having a HR staff will help manage these relations and conduct necessary background checks.

Residual Risk Justification: It would still have a moderate impact if the attack was still somehow successful, because it is possible for an employee to not have a criminal history and sell data if they are offered cash illegally, which is why it is rated a 3 for impact, and likely hood is rated 1 because this is something that won't happen as much as before due to the HR staff doing background checks.

Risk R03 Control Strategy

Current Situation: Currently, EtherSpace uses a single DMZ for all servers, which could be vulnerable to an attack where the attacker can move between servers.

Recommended Controls: Implement multiple DMZ's so that servers are categorised, which limits the attacker from moving laterally between the servers.

Implementation Considerations: This may be costly and will take some time as it will require an entire network restructure. This will require a few months for the engineers to plan and implement the restructure.

Residual Risk Justification: After the network is restructured, the impact reduces to 3 and the attack is more contained so the attacker will not be able to move laterally. The likelihood also decreases the chances of this happening.

Risk R04 Control Strategy

Current Situation: User accounts are set up with default passwords, and the user is given an option to change them, which means the servers are vulnerable to brute force attacks by the attacker, because these default passwords aren't as secure.

Recommended Controls: make default passwords one time use only. This will ensure that users are forced to create strong passwords.

Implementation Considerations: This will be very easy to implement, as all it requires is a slight change in the signup process to make it a requirement to change password.

Residual Risk Justification: The impact is still rated at 4, however the likelihood is reduced from 2 to 1.

Risk R05 Control Strategy

Current Situation: EtherSpace's firewall was configured at setup, but is not regularly audited so could contain some vulnerabilities if not updated regularly.

Recommended Controls: Conduct a firewall audit every 3 months to ensure the rules are up to date to protect against evolving threats.

Implementation Considerations: Might cost a moderate amount as will have to pay a staff to audit the firewalls, and wouldn't take too long, but has to be done every 3 months.

Residual Risk Justification: If bypassed by an attacker, the impact would still be the same, however, the likelihood decreases to almost never due to the constant update in the rules.

Risk R06 Control Strategy

Current Situation: EtherSpaces Office is in Wellington which lies on a fault line. This is vulnerable to earthquakes.

Recommended Controls: The only control that can be done in this case is to change the backup frequency from weekly to daily, to ensure the least amount of data is lost. Another possible control could be to strengthen the building to reduce the impact of the earthquake, however this could be very pricey.

Implementation Considerations: The cost would be very high to strengthen the building, however to change the backup from weekly to daily wouldn't be too much more expensive, it may require the current staff to do slightly more work, but this can be automated within a few months.

Residual Risk Justification: The impact is reduced to 4 because the backup is increased to daily instead of weekly, so less data is lost, however if the earthquake is extremely severe, then the building will not be able to withstand it, no matter the strength.

Control Implementation Summary

Overall my control strategy would be start with the easiest controls to implement, these include things like reconfiguring the alarm system, enforcing user to change default password and performing daily backups instead of weekly. These are all controls that can be implemented initially as a first step towards keeping EtherSpace secure.

One of the constraints of some of the other controls are hiring more staff. Currently, EtherSpace has only 3 employees, but as their business expands, I think it is crucial to employ a HR staff member who overlooks employee relations and conduct thorough background checks to keep internal data secure from being leaked.

Moving forward, the company should look to implement more controls such as having regular firewall audits, and also reconfigure the network structure to include more DMZ's. This will overall reduce the risks significantly and overall improve the business structure and operations.